

CIP / EtherNet/IP ATTACK & DEFEND

The Common Industrial Protocol on the wire — service codes, object classes, and how both sides read them.

ODVA · CIP Networks Library Vol 1

Purdue L1–L2 · Rockwell ControlLogix / CompactLogix / Micro8xx / PowerFlex · little-endian on the wire

Spoken by PIPEDREAM (CODECALL) · BAUXITE (AA26-097A)

CIP is objects. Every request — benign or hostile — is one sentence: **<SERVICE>** on **<CLASS>** : **<INSTANCE>** : **<ATTRIBUTE>**. Learn the triple and the protocol has no secrets.

1 WHERE IT LIVES

CIP objects · services · EPATH → application layer

EtherNet/IP (Vol 2) DeviceNet (Vol 3)
ControlNet (Vol 4) CompoNet (Vol 6)
CIP Safety (Vol 5) CIP Security (Vol 8)

TCP / UDP / IP → Ethernet

PORTS

44818/tcp explicit messaging (req/resp)
44818/udp ListIdentity discovery – **Shodan signature**
2222/udp implicit class-1 cyclic I/O
2221/both CIP Security TLS/DTLS — **rarely on**

Explicit = request/response, on demand. Implicit = cyclic I/O, no per-packet handshake, trivially spoofable.

2 THE OBJECT MODEL

DEVICE
└─ CLASS 0x01 Identity
 └─ INSTANCE 1, 2, 3 ...
 └─ ATTRIBUTE 7 = firmware rev

SERVICE 0x0E Get_Attribute_Single
acts on that path, encoded as **EPATH** segments.

READS AS

0x0E 0x01 : 1 : 7 → read firmware rev

⚠ TRAP — SERVICE CODES ARE CLASS-SCOPED

0x4E = Forward_Close on class 0x06, Read Holding Regs on 0x44, Read-Modify-Write on Logix tags. Never alert on a service without its class.

3 SESSION & CONNECTION CHAIN

1 ListIdentity 0x0063 who is out there, what firmware
2 ListServices 0x0004 what encapsulation is offered
3 RegisterSession 0x0065 → session handle
 NO CREDENTIALS. The handle is a cookie, not a login.
4a SendRRData 0x006F unconnected explicit (UCMM)
4b Forward_Open 0x54 class 0x06 → Connection ID pair
 SendUnitData 0x0070 connected explicit / class-3
5 class-1 implicit I/O udp/2222 cyclic
6 UnRegisterSession 0x0066

WHY THIS IS THE WHOLE FIGHT

Steps 1–3 are unauthenticated and pre-session. An attacker learns vendor, product code, serial and firmware revision — enough to pick a CVE — before sending a single command.

4 SERVICE CODES — THE WEAPON RACK

colour = what it does to the process

RECON READ WRITE CONTROL / DESTRUCTIVE PIVOT

UNIVERSAL — valid on almost any object class

0x01	Get_Attributes_All	any	dump every attribute of an instance
0x0E	Get_Attribute_Single	any	read one attribute
0x11	Find_Next_Object_Instance	any	walk instances — enumeration primitive
0x03	Get_Attribute_List	any	batch read
0x04	Set_Attribute_List	any	batch write of attributes
0x10	Set_Attribute_Single	any	change one config value
0x02	Set_Attributes_All	any	overwrite the whole instance
0x08	Create	any	instantiate an object
0x09	Delete	any	destroy an instance
0x0A	Multiple_Service_Packet	any	batch N services in one request — evasion
0x16	Save	any	persist config to non-volatile store
0x15	Restore	any	roll config back from store
0x05	Reset	Identity 0x01	type 0 = restart · type 1 = FACTORY DEFAULT
0x06	Start	Identity 0x01	mode change → RUN
0x07	Stop	Identity 0x01	mode change → PROGRAM · process halt

CONNECTION MANAGER — class 0x06

0x54	Forward_Open	0x06	open a CIP connection — precursor to control
0x5B	Large_Forward_Open	0x06	same, >511-byte payloads
0x4E	Forward_Close	0x06	tear the connection down
0x52	Unconnected_Send	0x06	route a request through a bridge / backplane

LOGIX TAG SERVICES — Symbol class 0x6B

0x4C	Read_Tag	0x6B	read a tag by symbolic name
0x52	Read_Tag_Fragmented	0x6B	large read
0x4D	Write_Tag	0x6B	write a setpoint / data-table value
0x53	Write_Tag_Fragmented	0x6B	large write
0x4E	Read-Modify-Write	0x6B	atomic bit set — flip a single coil

LEGACY TUNNEL — PCCC class 0x67

0x4B	Execute_PCCC	0x67	tunnel SLC-500 / PLC-5 commands behind CIP
------	--------------	------	---

5 HIGH-VALUE OBJECT CLASSES

0x01	Identity	vendor · serial · FIRMWARE REV → CVE. Hosts Reset.
0x02	Message Router	dispatches every explicit request
0x04	Assembly	the I/O data blob. Write = direct process manipulation.
0x06	Connection Manager	Forward_Open, Unconnected_Send (routing / pivot)
0x0F	Parameter	device configuration values
0x37	File	EDS + FIRMWARE download chain
0x41	Event Log	device-side evidence — DEFENDERS: pull this
0x44	Modbus	Modbus-over-CIP bridge — protocol hop
0x47	DLR	ring topology control — disrupt = network partition
0x5D	CIP Security	the control plane, if it is switched on
0x5E	EtherNet/IP Security	TLS/DTLS config
0x5F	Certificate Mgmt	device certificates
0x67	PCCC	legacy SLC / PLC-5 tunnel
0x6B	Symbol (Logix)	the TAG NAMESPACE. Enumerate = read the process design.
0x6C	Template (Logix)	UDT structure definitions
0xF3	Conn. Config (CCO)	connection provisioning
0xF4	Port	backplane / network port map — reveals topology
0xF5	TCP/IP Interface	write = re-IP the device
0xF6	Ethernet Link	link config + counters

THE CROWN JEWEL

Symbol object 0x6B + Get_Instance_Attribute_List dumps every tag name in the controller. PUMP_1_SPEED, VALVE_HS201_CMD — the process design, unauthenticated.

6 ATTACKER PLAYBOOK ICS Kill Chain — Stage 2

1 DISCOVER

ListIdentity 0x0063 broadcast on udp/44818, or a unicast sweep. Shodan: port:44818. Returns vendor, product code, serial, firmware rev, IP — unauthenticated, pre-session.

2 ENUMERATE

Get_Attributes_All on Identity · Find_Next_Object_Instance to walk classes · Get_Instance_Attribute_List on Symbol 0x6B to dump the tag namespace. Tag names leak the process semantics.

3 ESTABLISH

RegisterSession 0x0065 — no credentials required. Forward_Open 0x54 for a class-3 connection when you need ordered, connected messaging.

4 MANIPULATE

Write Tag 0x4D to a setpoint · Set_Attribute_Single 0x10 to change config · write the Assembly object 0x04 for direct I/O. Batch with Multiple_Service_Packet 0x0A to compress the burst.

5 DISRUPT

Stop 0x07 drops the controller to PROGRAM · Reset 0x05 type 1 restores factory defaults · flood Forward_Open to exhaust the connection table.

6 PERSIST / DESTROY

Firmware push via the File object 0x37 · PCCC tunnel 0x4B to legacy SLC/PLC-5 behind the controller · Unconnected_Send 0x52 to route deeper into the backplane.

WHY IT WORKS

Base CIP has no authentication, no encryption and no message integrity. The session handle is not a credential. Off-the-shelf tooling speaks it fluently: pycomm3, cppop, plcscan, Metasploit ethernetip modules.

7 DEFENDER PLAYBOOK capture → parse → triage

CAPTURE

bpf: tcp port 44818 or udp port 2222 or udp port 44818 or port 2221
TAP in preference to SPAN, positioned at the L2/L3 conduit.

ZEEK — ICSNPP-ENIP

enip.log · cip.log · cip_io.log · cip_identity.log
→ service, class, instance, tag, status per request

SURICATA

enip_command:0x006f; cip_service:0x4d; cip_class:0x6b
Always pair the service with the class — see TRAP, panel 2.

WIRESHARK

cip.service == 0x4d && cip.class == 0x6b
enip.command == 0x63

TRIAGE LOGIC

Is the service Write / Set / Stop / Reset / Forward_Open-then-write?
→ is the source an authorised EWS or HMI in the baseline?
→ inside a change window, matching a ticket?

write-class + non-EWS + no window → ESCALATE

★ THE FALSE-ZERO RULE

A manipulation-class count of **0** is a defensible Negative **only** when the benign-runtime classes — Read Tag 0x4C, Write Tag 0x4D, Forward_Open 0x54 — are non-zero in the same capture. Those prove the capture point actually sees the CIP conversation.

All-zero across every service is a capture gap, not a clean hunt. Report Non-Conclusive, never Negative.

8 NORMAL vs SUSPICIOUS

NORMAL

- HMI/SCADA polling Read Tag at a steady cadence
- EWS writes during a known change window
- class-1 I/O between established producer/consumer pairs
- ListIdentity from the asset-inventory scanner

SUSPICIOUS

- Write Tag / Set_Attribute / Stop / Reset from a non-EWS source
- ListIdentity from an internet-side or first-seen internal IP
- first-seen class-1 producer to a controller
- Forward_Open followed by a burst of writes
- Execute_PCCC from an unexpected host
- Multiple_Service_Packet batching write services
- Symbol-object enumeration sweep

9 HARDENING

- Controller keyswitch in RUN — a hardware veto on remote mode change and download.
- Enable CIP Security (Vol 8): TLS/DTLS on 2221, device authentication and integrity.
- Segment into cell/area zones; conduit-filter 44818 and 2222 to named EWS/HMI only.
- Allowlist by source — CIP has no auth, so the network IS the access control.
- Disable unused objects; strip the PCCC object where no legacy gear sits behind it.
- Signed firmware only; monitor the File object 0x37.
- Baseline the CIP conversation: which source, which service, which class.
- Ship the device Event Log (0x41) to the SIEM.
- Never expose 44818 to the internet — check Shodan/Censys against your own ASN.

Top 20 Secure PLC Coding Practices · IEC 62443-3-3 · NIST SP 800-82r3

10 ATT&CK for ICS

T0846	Remote System Discovery	ListIdentity sweep
T0888	Remote System Info Discovery	Get_Attributes_All
T0861	Point & Tag Identification	Symbol 0x6B enumeration
T0855	Unauthorized Command Message	any unsanctioned service
T0836	Modify Parameter	Write Tag / Set_Attribute
T0843	Program Download	logic transfer to controller
T0845	Program Upload	logic theft
T0889	Modify Program	logic tamper
T0858	Change Operating Mode	Start 0x06 / Stop 0x07
T0816	Device Restart / Shutdown	Reset 0x05
T0800	Activate Firmware Update Mode	File object 0x37

SEEN IN THE WILD

PIPEDREAM / CODECALL (CHERNOVITE) · BAUXITE Rockwell campaign, CISA AA26-097A